

Controls and compliance checklist

Internal Security Audit - Botium Toys

Date: July 22, 2026

Auditor: Javier Diaz

Does Botium Toys currently have this control in place?

Controls assessment checklist

Yes	No	Control
☐	☒	Least Privilege
☐	☒	Disaster recovery plans
☐	☒	Password policies
☐	☒	Separation of duties
☒	☐	Firewall
☐	☒	Intrusion detection system (IDS)
☐	☒	Backups
☒	☐	Antivirus software
☐	☒	Manual monitoring, maintenance, and intervention for legacy systems
☐	☒	Encryption
☐	☒	Password management system
☒	☐	Locks (offices, storefront, warehouse)
☒	☐	Closed-circuit television (CCTV) surveillance

- ☒ ☐ Fire detection/prevention (fire alarm, sprinkler system, etc.)
-

Does Botium Toys currently adhere to this compliance best practice?

Compliance checklist

Payment Card Industry Data Security Standard (PCI DSS)

Yes	No	Best practice
☐	☒	Only authorized users have access to customers' credit card information.
☐	☒	Credit card information is stored, accepted, processed, and transmitted internally, in a secure environment.
☐	☒	Implement data encryption procedures to better secure credit card transaction touchpoints and data.
☐	☒	Adopt secure password management policies.

General Data Protection Regulation (GDPR)

Yes	No	Best practice
☐	☒	E.U. customers' data is kept private/secured.
☒	☐	There is a plan in place to notify E.U. customers within 72 hours if their data is compromised/there is a breach.
☐	☒	Ensure data is properly classified and inventoried.
☒	☐	Enforce privacy policies, procedures, and processes to properly document and maintain data.

System and Organizations Controls (SOC type 1, SOC type 2)

Yes	No	Best practice
☐	☒	User access policies are established.
☐	☒	Sensitive data (PII/SPII) is confidential/private.
☒	☐	Data integrity ensures the data is consistent, complete, accurate, and has been validated.
☐	☒	Data is available to individuals authorized to access it.

Recommendations: I recommend implementing a Least Privilege access control policy to ensure employees only have access to the data and systems necessary for their specific roles. The company should focus on minimizing its attack surface by reducing unnecessary entry points and disabling unused services.

Botium Toys must establish a comprehensive Disaster Recovery Plan alongside a regular automated backup schedule. It is important to minimize downtime and prevent data loss. I suggest configuring periodic automation that securely stores backups with full version history, ensuring that every critical change is tracked, logged, and easily recoverable in the event of a ransomware attack, system failure, or natural disaster.

Strong data encryption protocols must be implemented for all credit card information and other sensitive personally identifiable information . Access to this encrypted data must be strictly restricted to authorized personnel only

The company must ensure continuous compliance with current legal and regulatory frameworks, including GDPR, PCI DSS, and SOC 2.